

Cybersecurity Analyst Project Report

Title: Detecting and Mitigating Brute-Force Attacks using Splunk SIEM **Analyst:** Harikrishna Raval

Date: April 2025

Executive Summary

This report outlines the simulation and detection of brute-force attacks using Splunk as a SIEM tool, along with the implementation of short-term and long-term mitigations. The goal of this project was to emulate a SOC analyst's workflow — from initial alert to incident response and hardening — to prevent future occurrences.

The attack simulation focused on repeated login failures followed by a successful login, which mimics a typical brute-force attack pattern. As a result of the findings, lockout policies were enforced, and system hardening strategies were implemented.

Tools & Environment

- **Splunk Enterprise (Trial License)**
 - **Windows 10 VM (Target)**
 - **Kali Linux (Attacker VM)**
 - **VirtualBox**
 - **PowerShell & Bash**
 - **Security Onion (for packet monitoring, optional)**
-

Attack Simulation Details

- **Type of Attack:** Brute-force (credential stuffing)
 - **Method:** Hydra used from Kali Linux to simulate repeated login attempts
 - **Target Service:** Windows RDP login
 - **Log Source:** Windows Security Event Logs (forwarded to Splunk)
 - **Indicators of Compromise (IOCs):**
 - Multiple login failures in quick succession
 - Successful login following multiple failures
 - Login attempts from a single IP to multiple user accounts
-

Detection via Splunk

SPL Query:

```
index=wineventlog EventCode=4625 OR EventCode=4624  
| stats count by Account_Name, host, EventCode, _time, src_ip  
| where count > 5
```

Observations:

- 25 consecutive EventCode 4625 (failed login attempts)
- 1 EventCode 4624 immediately after, same user, same IP
- All attempts within a 2-minute window

Alert Configuration:

- **Trigger:** >5 failed attempts followed by a successful login from the same IP within 2–5 minutes
 - **Severity:** High
 - **Action:** Email alert + Script to disable affected account (optional)
-

Immediate Response Actions (Short-Term)

- Account temporarily disabled
 - Source IP blocked via Windows Firewall rules
 - Administrator alerted
 - Forced password reset on compromised accounts
-

Long-Term Hardening Measures

- **Account Lockout Policy:**
 - Lock after 5 failed attempts
 - Lockout duration: 15 minutes
- **Password Policy Strengthened:**
 - Minimum 12 characters
 - Mix of upper/lowercase, numbers, symbols
- **Auditing & Logging:**

- Centralized log forwarding to SIEM
 - Increased verbosity of RDP and login logs
 - **System Hardening:**
 - Disabled unused services (e.g., Telnet)
 - Applied latest security patches
 - Implemented Group Policy to restrict RDP access
-

Lessons Learned

This simulation revealed the effectiveness of layered security: detection, response, and hardening. Splunk's real-time detection paired with automated or semi-automated responses ensures that brute-force attacks are both detectable and preventable.

Future improvements include:

- Integrating Splunk with SOAR tools for auto-remediation
 - Building anomaly detection for non-IP-based brute-force attempts
-

Appendix

Sample Logs (Anonymized)

EventCode=4625 | Account: hkraval | IP: 192.168.1.105 | Time: 10:04:12

EventCode=4625 | Account: hkraval | IP: 192.168.1.105 | Time: 10:04:18

...

EventCode=4624 | Account: hkraval | IP: 192.168.1.105 | Time: 10:05:01

References

- MITRE ATT&CK Technique T1110 – Brute Force
 - Microsoft Security Event Code Documentation
 - Splunk Security Essentials
-

End of Report